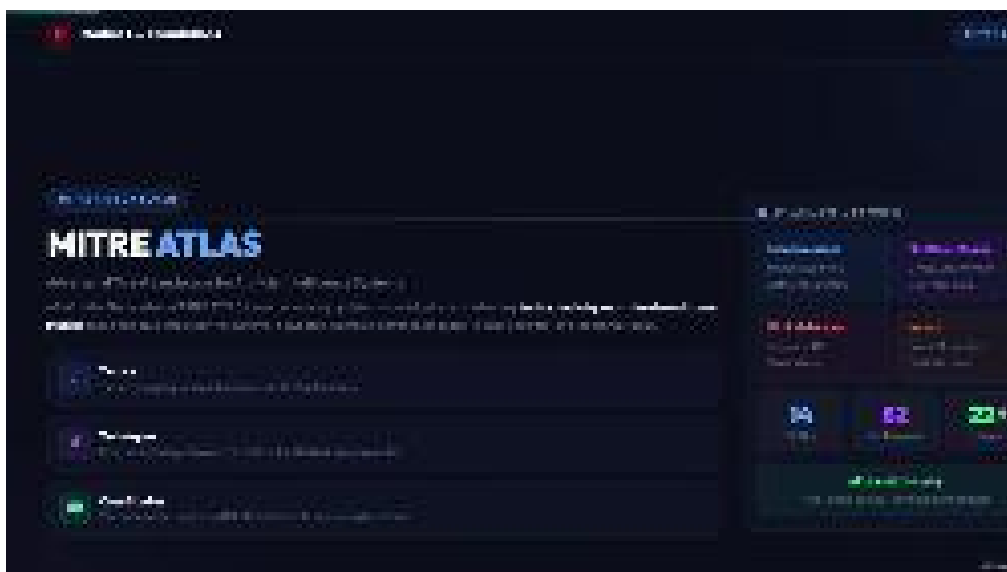


课程讲义

MITRE ATLAS + NIST 框架：AI 威胁建模实战指南

洺熙-AI 安全 & Codex

2026 年 5 月 17 日



视频作者 / 频道：洺熙-AI 安全

发布日期：2026-05-13

视频时长：7:17

视频链接：<https://www.bilibili.com/video/BV1CN516qE8v>

素材说明：B 站未提供可下载的中文 CC 或 AI 字幕，本讲义基于 Whisper 转写、视频画面、封面图和框架背景整理。

目录

1	课程定位：AI 红队为什么需要共同语言	2
1.1	从传统安全测试走向 AI / ML 红队	2
1.2	MITRE ATLAS 的角色：地图、词典、路线表与证据库	3
1.3	本章小结	3
2	ATLAS 的基本构件：战术、技术、过程与证据	4
2.1	TTP：从攻击意图到可复盘动作	4
2.2	Matrix Preview：把 AI 攻击放到阶段坐标系中	5
2.3	真实案例与开放知识库	6
2.4	本章小结	6
3	ATLAS 攻击链：从侦察到影响的 12 阶段	7
3.1	前置阶段：侦察、资源开发与初始访问	7
3.2	攻击准备与模型接触：从 ML attack staging 到执行	8
3.3	进入之后：持久化、防御规避与环境发现	9
3.4	结果阶段：收集、外传与影响	10
3.5	本章小结	10
4	红队如何使用 ATLAS 规划测试	10
4.1	从框架到测试计划：范围、目标与记录	11
4.2	与传统渗透测试攻击计划的类比	12
4.3	报告项：把阶段发现转成治理语言	13
4.4	本章小结	13
5	NIST AI RMF：把红队测试接入风险治理	13
5.1	Govern 与 Map：把测试范围变成治理对象	15
5.2	Measure 与 Manage：从发现风险到处置闭环	15
5.3	红队在四大功能中的位置	16
5.4	本章小结	16
6	NIST AI 600-1、对抗性测试与后续 C2C 伏笔	16
6.1	红队测试在 AI 生命周期中的回路	18
6.2	NIST AI 600-1 对 adversarial testing 的要求	19
6.3	C2C 与下一个视频接口	19
6.4	本章小结	19
7	总结与延伸	19
7.1	给读者的三个带走判断	20

1 课程定位：AI 红队为什么需要共同语言

这节课回到基础模块，讲者把主题放在 MITRE ATLAS 上。开场里有一个小提醒：MITRE 的读音本身并非重点，真正需要抓住的是 ATLAS 在 AI / ML 安全中的用途。它给红队、治理人员、开发团队和风险负责人提供一套共同语言，让大家在谈论 AI 系统威胁时能指向同一张地图，而非各说各的“危险”“漏洞”“攻击面”。

本节适合先放一张 ATLAS 总览图，让读者把“共同语言”这个抽象说法落到具体界面上：左侧是 ATLAS 的定义入口，右侧是矩阵预览和规模统计。

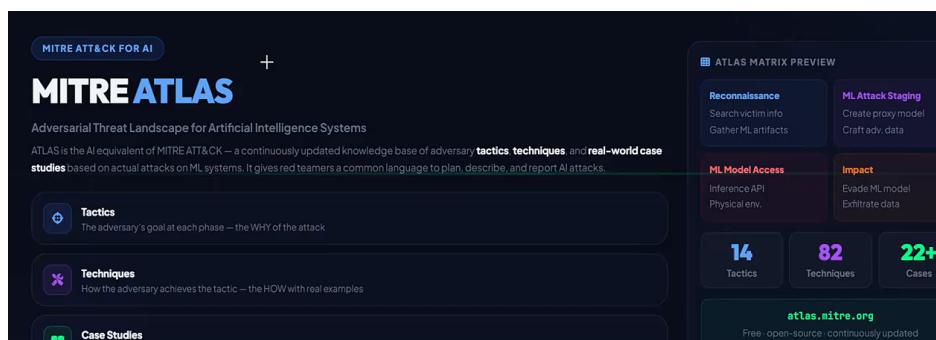


图 1: MITRE ATLAS 总览页：ATLAS 被呈现为面向 AI / ML 系统的对抗知识库，图中同时给出 Tactics、Techniques、Case Studies 三个入口。¹

1.1 从传统安全测试走向 AI / ML 红队

传统安全测试里，渗透测试人员经常围绕网络、主机、身份、应用接口和权限边界来组织工作。AI / ML 系统把这个问题变得更绕：资产不再只有服务器和代码仓库，还包括训练数据、模型权重、推理 API、提示词链路、模型输出、人工反馈流程，以及部署模型所处的物理或业务环境。换句话说，AI 系统的“门”很多，有些门看起来像数据入口，有些门看起来像普通业务调用，还有些门藏在模型行为里。

这里需要引入第一个核心概念：**AI 威胁建模**（AI threat modeling）。它指的是系统化识别 AI 系统中的资产、入口、对手目标、攻击面、风险场景和缓解优先级的过程。可以把它类比为给一栋复杂建筑画消防图：先标出入口、通道、关键房间、易燃材料和疏散路线，再决定演练怎么做、警报怎么设、人员怎么分工。放到 AI 系统中，关键房间可能是训练数据，通道可能是推理接口，易燃材料可能是未经验证的数据依赖或模型输出信任链。

AI 威胁建模的直觉

AI 威胁建模解决的是“先看清系统，再讨论风险”的问题。若没有资产清单、入口视图和对手目标，红队测试容易变成零散尝试；有了威胁建模，测试才能被组织成可解释、可复盘、可治理的风险分析。

第二个核心概念是 **red teaming**，本文统一称为红队测试或红队演练。它是在授权条件下模拟对手行为，用来发现 AI 系统风险、验证防护有效性，并把发现转化为治理改进的活动。这里的

¹视频画面时间区间：00:00:24.6–00:00:31.6；从 00:00:25.0 抽帧并截去顶部平台标识与底部字幕区域。

“授权条件”很关键：红队测试的价值来自边界清楚、目标明确、证据可追溯。离开授权范围，它就失去了安全工程的语境。

可以用一个简单集合来表示这件事：

$$R = (A, S, G, E)$$

其中， R 表示一次红队任务， A 是被授权测试的 AI / ML 资产集合， S 是测试范围， G 是对手可能追求的目标， E 是测试过程中形成的证据。这个公式的作用并非给出操作流程，而是提醒读者：红队活动必须同时有对象、边界、目标和证据。少了其中任何一项，后续报告就会变得含糊。

1.2 MITRE ATLAS 的角色：地图、词典、路线表与证据库

MITRE ATLAS 的全称是 *Adversarial Threat Landscape for Artificial-Intelligence Systems*，可译为“面向人工智能系统的对抗性威胁景观框架”。在这门课中，ATLAS 被讲者定位为面向 AI / ML 系统的对抗知识库与矩阵框架；它会随着真实攻击、机器学习系统研究和对抗知识不断更新，并为 red teamers 提供规划、描述和报告 AI tactics 的共同语言。

要理解 ATLAS，最好的方式是把它拆成四种工具：

- **地图**：地图回答“现在处在哪个区域”。在 ATLAS 里，区域对应攻击阶段、战术目标或模型相关环节。它帮助团队把讨论从抽象恐惧拉回到具体位置。
- **词典**：词典回答“这个词是什么意思”。同一个行为在不同团队里可能被叫成不同名字，ATLAS 让战术、技术、证据和案例拥有更统一的命名。
- **路线表**：路线表回答“从一个阶段到另一个阶段通常怎样衔接”。它用于规划和报告，帮助红队把离散发现串成有顺序的测试叙事。
- **证据库**：证据库回答“这个概念凭什么成立”。讲者特别强调，ATLAS 有真实世界案例和研究证据，把概念连接到现实中的攻击与机器学习系统研究。

这四者差别很重要。地图强调位置，词典强调命名，路线表强调阶段关系，证据库强调现实支撑。很多初学者会把它们混成一份“攻击清单”，然后误以为看完清单就能执行测试。更准确的理解是：ATLAS 先让团队看懂地形、说同一种语言、按阶段组织工作，并在报告里引用证据。

ATLAS 的核心作用

ATLAS 的价值在于把 AI 红队测试从“零散经验”推进到“可命名、可定位、可报告、可对照证据”的共同语言。它让红队、蓝队、模型团队和风险治理团队能围绕同一个坐标系讨论问题。

这一点也解释了讲者为什么先讲 ATLAS，再谈后续的风险治理框架。红队发现若没有共同语言，就很难进入组织流程；风险治理若没有可追溯的测试证据，也容易变成纸面合规。后面的课程会把 ATLAS 与 NIST 相关框架放到同一个视野中，但本节只保留伏笔：ATLAS 解决“怎样描述 AI 对抗风险”的语言问题，后续框架会继续讨论这些发现怎样进入治理闭环。

1.3 本章小结

本节建立了课程的入口：AI / ML 系统让安全测试从传统应用和基础设施扩展到数据、模型、推理接口和模型行为，因此需要 AI 威胁建模来先画清系统，再讨论风险。红队测试是在授权边界内模拟对手行为，用证据帮助组织发现风险、验证防护并推动治理。

MITRE ATLAS 在这里承担共同语言的角色。它像地图，帮助定位阶段；像词典，统一概念命名；像路线表，组织测试叙事；也像证据库，把抽象概念连接到真实案例与研究材料。读者先记住这个定位，下一节再进入 ATLAS 的基本构件：战术、技术、过程与证据。

2 ATLAS 的基本构件：战术、技术、过程与证据

上一节解决“为什么需要共同语言”。这一节进入 ATLAS 的内部构件：它怎样把一次面向 AI / ML 系统的对抗行动拆成“为什么做、怎样做、具体怎样发生、凭什么确认”。讲者在 00:00:56 之后给出关键线索：tactics 回答攻击者在某个阶段想达成什么目标，也就是 attack 的 why；techniques 说明攻击者如何达成这些目标，也就是 how；真实案例和证据则把概念连接起来，帮助学习者理解攻击链。

2.1 TTP：从攻击意图到可复盘动作

ATLAS 借鉴了 MITRE ATT&CK 的矩阵化表达。这里的 ATT&CK 可以理解为“对抗战术、技术与共同知识库”的经典安全框架；在本课语境中，它只作为类比出现：ATLAS 把类似的组织方式迁移到 AI / ML 系统上，让 AI 红队能用阶段、战术、技术和案例来描述问题。

ATLAS 中最需要先掌握的是 TTP，即 **Tactics, Techniques, and Procedures**，中文可译为战术、技术与过程。

- **Tactics (战术)**：回答“为什么做”。它描述对手在某一阶段的目标，例如获取目标信息、接触模型、造成影响等。
- **Techniques (技术)**：回答“怎样做”。它描述达成战术目标的手段类型，例如通过某类入口接触模型，或围绕某类 AI 资产收集信息。
- **Procedures (过程)**：回答“在某个场景中具体怎样发生”。它比技术更贴近案例，但在教学笔记中应保持抽象，避免写成攻击操作步骤。
- **Evidence (证据)**：回答“凭什么这么判断”。它可以来自真实世界案例、研究材料、测试日志、截图、模型响应记录或报告观察结果。

可以用一个层级关系表示：

Evidence → Procedure → Technique → Tactic

箭头表示“向上支撑”。证据支撑某个过程的存在，过程说明某项技术在具体场景中的表现，技术服务于某个战术目标。反过来看，战术像目的地，技术像路线选择，过程像一次实际行程，证据像路上的票据、照片和时间记录。

地图、词典、路线表、证据库的差别

地图让人知道位置，词典让人统一叫法，路线表让人理解阶段衔接，证据库让人知道判断依据。TTP 位于词典与路线表之间：它既给行为命名，也把行为放进攻击阶段。Evidence 则保证这些命名有现实支撑。

这种分层能避免两个常见误解。第一，把 tactic 当成具体技术会让讨论过早落到动作细节，忽略对手目标。第二，把 evidence 当成可有可无的附件会削弱报告可信度。对红队报告来说，只有“发现了一个问题”还不够；更有价值的是说明这个问题属于哪类战术目标、对应哪类技术、观察到哪些证据，以及这些证据对系统风险意味着什么。

2.2 Matrix Preview: 把 AI 攻击放到阶段坐标系中

讲者随后展示 ATLAS Matrix Preview，并口头列出若干阶段和条目：reconnaissance、victim information、gather ML artifacts、ML attack staging、proxy model、adversarial data、ML model access、inference APIs、physical environments、impact、evade ML model、exfiltrate data 等。这里要注意，Whisper 字幕中的若干英文有误识别，例如 ‘advanced data’ 应按语境理解为 adversarial data，‘atlas.metro.org’ 应修正为 ‘atlas.mitre.org’。

第 2 节开始把 ATLAS 从“是什么”推进到“怎样组织知识”。这里先用视频中的矩阵预览承接讲者对 reconnaissance、ML attack staging、ML model access 与 impact 的说明。



图 2: ATLAS Matrix Preview 细节：画面把侦察、攻击准备、模型访问与影响阶段放在同一矩阵中，并标出 14 个 tactics、82 个 techniques 与 22+ 个案例。²

TTP 可以理解为三层索引：战术说明对手意图，技术说明达成方式，过程与证据说明真实发生时留下的细节。这个分层图用于把字幕中的“why / how / examples”关系压缩成一眼能读懂的结构。

Matrix Preview 的教学价值在于建立坐标系。若把 AI 攻击看成一段旅程，横向可以看阶段推进，纵向可以看每个阶段下有哪些技术或证据类型。这样一来，红队讨论就不再停留在“模型有风险”这种大词上，而是能说清楚风险出现在侦察、模型访问、攻击准备、规避、外传还是影响附近。

Matrix Preview 的读法

读 Matrix 时，先看阶段，再看战术目标，最后看技术与证据。阶段提供位置，战术提供意图，技术提供方法类型，证据提供判断依据。这个顺序能让报告保持清楚，也能降低把课程内容误读成攻击手册的风险。

²视频画面时间区间：00:01:41.6–00:02:20.1；从 00:02:20.0 抽帧，依据 contact sheet 中 frame_0028–frame_0030 的相邻候选裁出右侧矩阵区域。

³视频画面时间区间：00:00:56.0–00:01:40.8；脚本生成的教学示意图，依据本节字幕对 tactics、techniques 与 examples / evidence 的解释绘制。

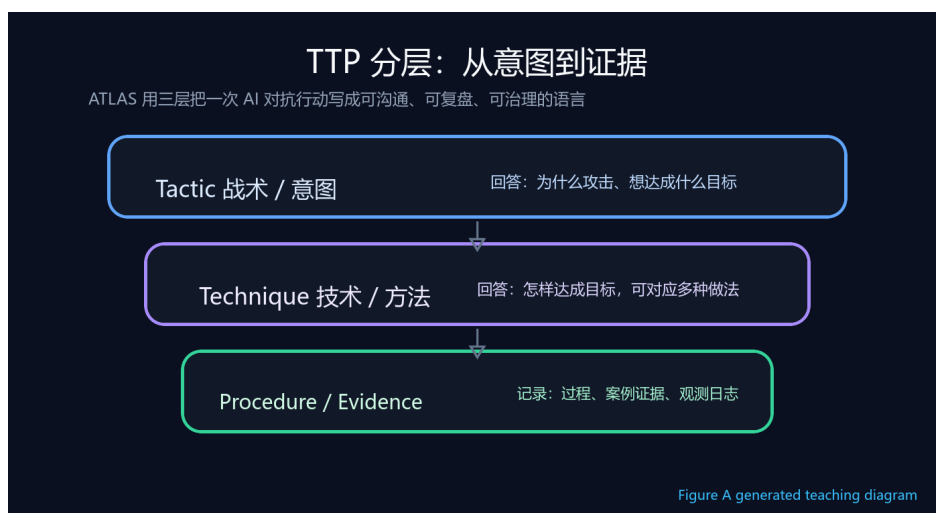


图 3: TTP 分层示意图：Tactic 回答攻击意图，Technique 回答实现方法，Procedure 与 Evidence 负责把方法落到具体过程和证据。³

本节只做预览，不展开第 3 节会讲的完整攻击链。读者需要先建立一个安全的抽象层：ATLAS 告诉红队“要观察哪些类型的现象”和“怎样命名这些现象”，并未要求学习者把每一项技术转写为可执行步骤。比如 inference API 在这里只是模型访问入口的例子，proxy model 只是攻击准备阶段中可能出现的模型相关对象，adversarial data 只是对抗样本数据这一类风险材料的名称。

2.3 真实案例与开放知识库

讲者强调 ATLAS 有真实世界的证据，并且是开放、持续更新的知识库。字幕中提到的规模是讲者口径：14 个战术、82 个技术、22 个例子；具体数字会随着 ATLAS 更新而变化，写作中应保留为视频中的说法，而不要把它当成永久不变的版本声明。

开放知识库有三个意义。第一，它让学习者能从真实案例里理解抽象概念，而非只背术语。第二，它让团队报告能引用共同来源，减少“这个风险到底叫什么”的争论。第三，它让 AI 安全实践跟随现实攻击、机器学习研究和防护经验一起更新。

这里的“证据”要理解得宽一些。它可以是公开案例，也可以是论文或研究复现中的观察，还可以是在授权测试中采集到的系统行为记录。证据像安全报告里的地基：没有地基，战术和技术只是漂亮的标签；有了地基，标签才能支撑风险判断。

不要把 ATLAS 当作攻击操作清单

ATLAS 适合用于威胁建模、红队规划、测试记录和风险报告。它列出阶段与技术类别，并不等于提供可直接执行的攻击步骤。学习时应关注命名、结构、证据和治理接口，避免把框架误读成操作教程。

2.4 本章小结

本节完成 ATLAS 基本构件的拆解。Tactics 回答对手为什么行动，techniques 回答对手怎样达成目标，procedures 描述具体场景中的实施形态，evidence 则支撑判断和报告。TTP 的价值在于把攻击意图、方法类型和可复盘材料组织到同一个层级里。

Matrix Preview 则把这些构件放进阶段坐标系中。它像一张路线表，帮助红队从 reconnaissance、ML attack staging、ML model access 到 impact 等阶段组织观察与报告。真实案例和开放

知识库让这些概念有现实依据。下一节会继续沿着 ATLAS 的阶段视角，讲从侦察到影响的攻击链概览，但仍应保持在授权测试和风险分析的边界内。

3 ATLAS 攻击链：从侦察到影响的 12 阶段

前两节已经把 ATLAS 放进了 TTP 与矩阵化知识库的语境。本节继续沿着讲者在 00:02:28–00:04:27 展开的技术线，把一次面向 AI / ML 系统的对抗行动拆成一条有顺序的攻击链。这里的重点是理解红队测试的路线图：每个阶段回答“测试要观察什么风险、留下什么证据、如何与防护控制对应”。它不能被读成未授权攻击手册。

阅读边界：路线图不等于操作手册

本节只在授权红队、风险评估和防护验证语境下讨论 ATLAS 阶段。所谓“攻击链”，在这里更像一张消防演练路线图：它告诉演练团队从哪个区域开始检查、哪些门禁和报警器需要被验证、最后如何记录风险。它不提供绕过检测、窃取模型、外传数据或制造影响的可执行细节。

3.1 前置阶段：侦察、资源开发与初始访问

讲者先强调 ATLAS 技术线需要“仔细理解”，因为它把一件混乱的事变成了阶段化叙事。对 AI / ML 系统来说，第一组阶段发生在真正接触目标能力之前，主要处理三个问题：目标在哪里、需要哪些授权测试资源、从哪个被批准的接触面开始验证。

可以把讲者口中的 12 个阶段写成一个有序集合：

$$S = \{s_1, s_2, \dots, s_{12}\}$$

其中：

- S 表示一次授权 AI 红队测试所参考的阶段集合；
- s_i 表示第 i 个阶段，例如 s_1 是侦察， s_2 是资源开发；
- 下标 i 表示阶段顺序，顺序代表分析路径，不代表现实中每次测试都机械地线性推进；
- $s_i \rightarrow s_{i+1}$ 表示测试证据从一个问题域过渡到下一个问题域，例如从资产识别过渡到接触面验证。

这个形式化表达的价值很朴素：它让红队和治理团队谈同一张地图。若没有阶段序列，测试报告容易变成零散发现；有了 S ，每条发现都可以挂到一个阶段上，说明它属于资产暴露、访问控制、模型行为、数据保护，还是业务影响。

前三个阶段的核心含义

侦察 (reconnaissance) 关注 ML 资产与目标边界：有哪些模型、数据流、推理入口、物理或线上环境值得纳入授权测试范围。**资源开发 (resource development)** 关注测试所需的专用模型、工具、样本或记录模板，强调准备测试资源。**初始访问 (initial access)** 关注被允许验证的第一类接触面，例如某个推理 API、应用入口、测试环境或受控物理接口。

侦察阶段容易被误解为“到处找目标”。在红队测试里，更准确的理解是画出资产地图：哪些模型是真正的安全对象，哪些数据管线会影响模型行为，哪些入口会暴露推理能力，哪些依赖组件虽然不显眼却会改变风险。传统渗透测试会先梳理域名、服务、端口与身份边界；AI 红队则要额外关心模型版本、训练或微调数据来源、推理接口、提示层、评估集、内容过滤器、监控与人工复核流程。

资源开发阶段也应保持防御视角。它指向测试夹具和证据采集能力：例如构造一套受控的测试输入类别、准备用于对比的代理模型或影子评估环境、确定记录模型响应和安全控制状态的格式。这里的“资源”像实验室里的量尺、砝码和记录表，目的是让测试可重复、可审计、可回放。

初始访问阶段则把路线图从“知道系统”推进到“接触系统”。在授权场景下，这一步必须由范围和规则约束：测试账号、测试环境、允许触达的 API、禁止触达的数据域、可用时间窗、紧急停止条件，都要在计划里写清楚。这样后续阶段才有证据价值，否则风险发现会混入越界行为，报告也会失去治理意义。

第 3 节的视觉重点是完整攻击链。全景图先承担“路线图”的功能：读者能看到 12 个阶段如何从 Recon 推进到 Impact。

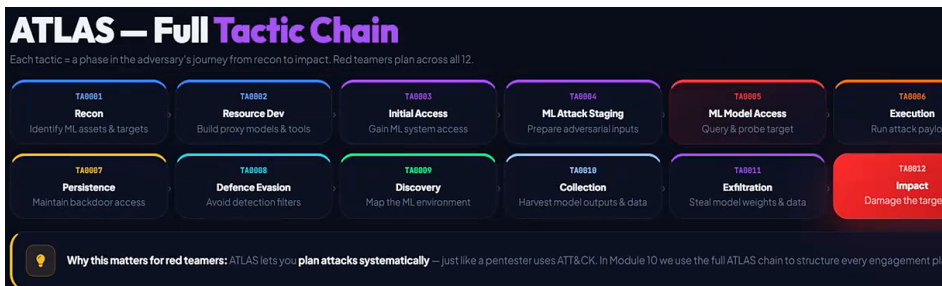


图 4: ATLAS 阶段链全景：12 个链路节点从 Recon、Resource Dev、Initial Access 一直推进到 Exfiltration 与 Impact。⁴

随后可以局部放大后半段，让 Discovery、Collection、Exfiltration、Impact 这几个结果相关阶段更清楚。它适合作为“攻击链细节”插在讲解后置阶段的位置。

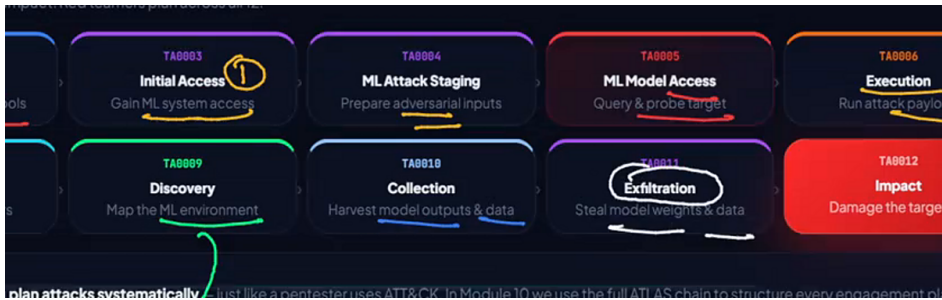


图 5: 攻击链后半段细节：画面突出模型访问后的发现、收集、数据外传与影响阶段，显示攻击链后半段怎样从环境识别走向结果。⁵

3.2 攻击准备与模型接触：从 ML attack staging 到执行

讲者随后进入 ML attack staging、ML model access 与 execution。若把前置阶段看成“拿到地图和实验器材”，这一组阶段就是“把测试问题摆上实验台”。它依然服务于验证防护，而非鼓

⁴ 视频画面时间区间：00:02:28.1–00:02:45.0；从 00:02:34.0 抽帧，选择无手写遮挡的完整链路画面并裁去下方空白。

⁵ 视频画面时间区间：00:03:55.0–00:04:23.0；从 00:04:23.0 抽帧，依据 frame_0053–frame_0055 裁出后半段 tactic 细节。

励攻击动作。

ML attack staging 可以译作“机器学习攻击准备阶段”。它处理的是测试输入、对抗样本类别、代理模型、评估条件与证据记录方式。代理模型（proxy model）在这里可以理解为一块训练用的沙盘：红队在沙盘上推演模型行为的可能边界，再把经过批准的测试项投向真实或受控目标环境。对抗性数据（adversarial data）则像压力测试中的载荷类别，用来观察系统在异常、边界、误导或分布偏移输入下的表现。

代理模型与对抗性数据的直觉

代理模型不是“偷来的目标模型”的同义词。它在合规红队中常常是一个用于预演和校准测试假设的替身；对抗性数据也不等于危险 payload，它可以是一组被治理团队批准的测试样本类别。二者的共同作用是把“模型可能在哪里失效”变成可观察、可记录、可复核的测试问题。

ML model access 是模型访问阶段，讲者提到推理 API 与物理环境。这里的“访问”既可能是线上推理服务，也可能是嵌入式、机器人、摄像头、传感器或其他物理部署场景。AI 系统的攻击面往往跨越软件、数据、模型和环境四层：软件层关心接口和身份，数据层关心输入输出与日志，模型层关心行为边界，环境层关心真实世界信号如何进入模型。

执行（execution）阶段是把已批准的测试项真正运行起来，并观察模型、应用和防护控制的反应。为了避免把章节写成攻击剧本，本文只强调执行阶段的证据结构：输入类别、触达入口、系统响应、监报告警、人工复核结果、业务影响判断。换句话说，执行阶段要回答“这个风险能否被观察到”，以及“现有控制是否按预期工作”。

阶段推进的证据链

对授权红队而言，阶段推进的最低要求是证据闭环：每个阶段都应留下范围依据、测试假设、观察结果和报告映射。若某一阶段没有证据，后续结论就像缺了一节的链条，读者很难判断风险来自模型本身、接口设计、数据治理，还是监控响应。

3.3 进入之后：持久化、防御规避与环境发现

讲者接着提到 persistence、defense evasion 与 discovery。传统安全语境里，这些词很容易让人想到真实入侵；放在本课程的红队语境中，它们应被解释为防护能力验证的测试类别。

持久化（persistence）关注“访问或影响是否会在一次交互之后继续存在”。在 AI / ML 系统里，这可能表现为状态、记忆、配置、缓存、检索索引、微调数据、插件权限或工作流上下文的残留风险。授权红队要验证的是：系统是否会把一次测试输入带来的异常状态保留下来，是否有清理机制，是否能识别不该长期存在的行为改变。

防御规避（defense evasion）关注检测过滤、异常检测、策略引擎和人工复核等机制是否可靠。讲者提到 detection filters 和 anomaly-based detections，这里应理解为防护控制的验证对象。红队报告不需要披露绕过技巧，必须记录的是控制点是否出现漏报、误报、延迟或上下文丢失。

发现（discovery）阶段则是在已授权范围内完整映射 ML 环境。它像进入一栋建筑后查看楼层图：有些房间没有挂门牌，但真实存在；有些通道不在最初清单里，却与目标系统相连。AI 系统中的“隐藏房间”可能是未公开的模型版本、辅助分类器、内容过滤模型、检索库、评估服务、日志管线、人工审核队列或外部工具调用链。

常见误区：把防御规避写成绕过技巧

防御规避在红队报告中应表达为控制验证问题：哪个检测点被测试、期望看到什么告警、实际记录了什么、缺口会造成什么风险。若报告沉迷于具体规避路径，就会偏离课程目标，也会给治理团队增加无谓暴露。

3.4 结果阶段：收集、外传与影响

最后一组阶段是 collection、exfiltration 与 impact。它们回答“如果前面的缺口没有被治理，最坏会怎样”。这一组尤其需要保持克制，因为它最容易被写成操作细节。教学上只需要理解三种结果的差异。

收集（collection）关注模型、数据或上下文材料是否可能被聚合到攻击者视角下。对于 AI 系统，收集对象可能包括模型输出、提示上下文、检索片段、业务数据片段、评估结果、日志线索或环境信息。授权红队真正要评估的是数据最小化、输出约束、权限隔离和日志保护是否有效。

数据外传（exfiltration）关注敏感信息是否可能离开预期边界。这里的“边界”既可以是网络边界，也可以是应用边界、租户边界、模型上下文边界或组织数据治理边界。报告层面应说明边界定义、外传风险类别、证据摘要和建议控制，避免给出可复制的外传路径。

影响（impact）关注最终伤害：模型行为被扭曲、敏感数据泄露、业务流程被误导、安全控制失效、用户受到错误建议、组织产生合规或声誉损失。影响阶段像事故复盘里的“损害评估”：它把技术发现翻译成业务语言，让治理团队知道哪些风险应该优先处理。

12 阶段作为红队路线图

ATLAS 攻击链的价值不在于制造一串动作清单，而在于把 AI 红队测试组织成可讨论的路线图：前置阶段界定资产与接触面，中间阶段验证模型访问和执行行为，后置阶段检查持续影响、防护控制、环境可见性、数据边界与业务伤害。每个阶段都应服务于授权、证据和改进。

3.5 本章小结

本节把讲者在 00:02:28–00:04:27 展开的 ATLAS 技术线整理为 12 个阶段：侦察、资源开发、初始访问、ML attack staging、模型访问、执行、持久化、防御规避、发现、收集、数据外传与影响。它们构成一张红队测试路线图，帮助团队把 AI / ML 风险从“感觉有问题”变成“在哪个阶段、哪个控制点、留下了什么证据、造成什么影响”。

读者需要带走两点。第一，阶段顺序是分析坐标，不是现实攻击的机械脚本；红队可以根据授权范围和测试目标选择其中一段或多段。第二，越靠近收集、外传、影响这些结果阶段，越要把文字收束到风险、证据、边界和治理建议上。这样写出来的 ATLAS 才能服务 AI 安全建设，而不会滑向危险的操作说明。

4 红队如何使用 ATLAS 规划测试

讲者在 00:04:27–00:04:56 用很短的时间回答了一个关键问题：为什么 ATLAS 对 red teamers 重要？原因是 ATLAS 给红队一组“需要经历的步骤”，让 AI 系统测试可以像传统渗透测试的攻击计划一样被规划、记录和复盘。上一节已经展开阶段链，本节只讲如何把阶段链转化为授权红队场景下的测试计划。

从框架到计划的转换

ATLAS 本身是一套描述语言和阶段地图。红队计划要把它转译成四类可执行的管理对象：测试范围、测试目标、证据要求、报告项。只有完成这一步，ATLAS 才会从“术语清单”变成项目管理、风险评估和治理沟通都能使用的测试方案。

4.1 从框架到测试计划：范围、目标与记录

红队拿到 ATLAS 后，第一步是确定范围（scope）。范围回答“什么可以测、什么不能测、谁授权、何时停止”。在 AI / ML 场景中，范围通常包括模型或应用版本、推理接口、测试账号、数据域、日志访问权限、允许使用的测试样本类别、禁止触达的生产资产，以及紧急联系人。范围像地图边界线，线外区域即使技术上可达，也不属于本次演练。

第二步是确定目标（objectives）。目标要从 ATLAS 阶段中抽象出来，例如：验证模型访问控制是否有效，验证内容过滤器能否记录异常输入类别，验证检索增强系统是否会泄露越权上下文，验证监控是否能关联模型响应与业务事件。目标要足够具体，方便事后判断达成与否；同时不能写成具体攻击动作。

第三步是设计证据（evidence）。证据是红队测试与普通讨论的分界线：没有证据，发现只能算猜测。证据可以包括授权记录、测试输入类别描述、系统响应摘要、日志截图、告警编号、人工复核记录、时间线、影响分析和复现实验条件。证据不需要公开敏感输入全文；对高风险材料，可以只保留哈希、脱敏摘要或受控附件位置。

ATLAS 在这一节从“知识库”落到“测试计划”。红队需要把阶段、目标、证据和报告项串起来，形成可复盘的行动设计。

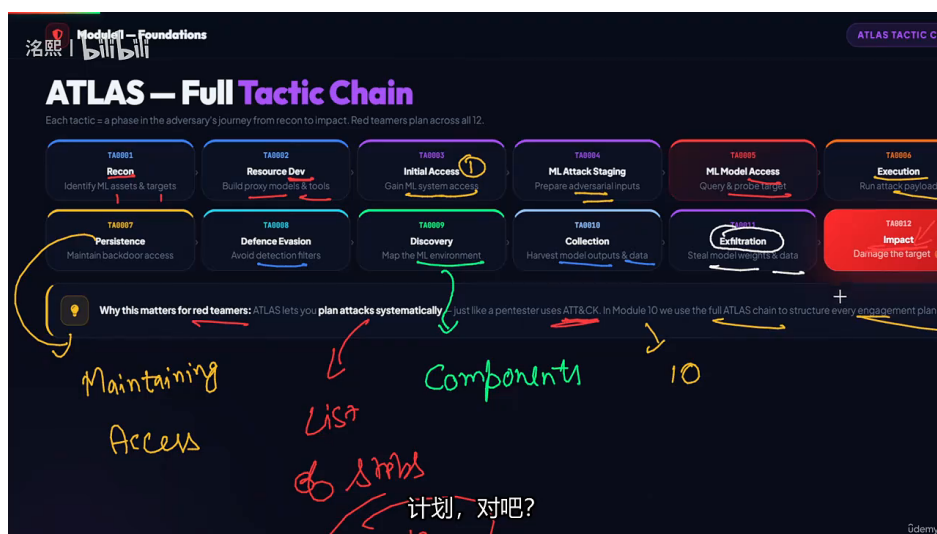


图 6: ATLAS 阶段链被用来组织红队计划：画面同时显示 Recon、Resource Dev、Initial Access、ML Attack Staging、ML Model Access、Execution、Persistence、Defence Evasion、Discovery、Collection、Exfiltration 与 Impact，并在下方强调 red teamers 可以用它系统规划测试。⁶

测试计划的四列表

一个简洁的 ATLAS 测试计划可以被压成四列表：阶段说明对应 ATLAS 位置，目标说明要验证的风险假设，证据说明测试后必须留下什么，报告项说明发现如何进入治理流程。这张

⁶视频画面时间区间：00:04:27–00:04:56；最终抽帧时间点：00:04:55.200。

表像实验课的记录纸，让红队、蓝队、模型团队和管理者围绕同一套材料沟通。

可以用一个抽象映射表示从 ATLAS 阶段到测试计划的转换：

$$P : s_i \mapsto (g_i, e_i, r_i)$$

其中：

- P 表示测试计划映射；
- s_i 表示第 i 个 ATLAS 阶段；
- g_i 表示该阶段的测试目标（goal），例如验证某类控制是否工作；
- e_i 表示该阶段要求收集的证据（evidence），例如日志、响应摘要、告警记录；
- r_i 表示该阶段进入报告的条目（report item），例如风险描述、影响、缓解建议与责任团队。

这个式子并不追求数学复杂度，它只是提醒红队：每个阶段都要落到目标、证据和报告项。若某个 s_i 只能写出阶段名，却写不出 g_i, e_i, r_i ，那它暂时还不是一个合格的测试计划项。

4.2 与传统渗透测试攻击计划的类比

讲者用传统 pentester 的攻击计划作类比：渗透测试人员会按计划推进，AI 红队也使用 ATLAS 计划。这个类比很有用，但需要掌握边界。

传统渗透测试计划通常围绕资产发现、漏洞验证、权限边界、横向移动可能性、数据访问和影响评估展开。AI 红队计划保留了这种“先建图、再验证、再评估影响”的骨架，同时多出几类 AI 独有对象：模型行为、提示上下文、训练或微调数据影响、推理 API、内容安全策略、检索增强组件、代理工具调用、模型监控与人工复核流程。

类比的正确用法

传统渗透测试的攻击计划提供项目节奏：范围、假设、步骤、证据、报告。ATLAS 为 AI 红队提供领域坐标：模型资产、ML attack staging、模型访问、防护规避验证、数据边界和影响。二者相接，形成一份授权测试计划；计划的目标是发现并降低风险。

这个类比还帮助团队理解“阶段”和“动作”的差别。阶段是一类问题域，例如发现、收集或影响；动作是具体执行方式。红队计划应把阶段写清楚，把动作控制在授权测试条件内，并且把可复核证据放在报告中心。这样做的好处是：即使不同团队使用不同工具，也能用 ATLAS 阶段对齐结果。

另一个容易忽略的点是报告语言。传统渗透测试报告常用漏洞、利用条件、影响和修复建议组织内容；AI 红队报告还要补充模型语境：模型版本、输入输出边界、触发条件类别、行为稳定性、误报/漏报、数据治理影响、人工复核位置，以及是否需要重新测试。ATLAS 阶段可以成为报告目录的骨架，让管理层看到风险从哪里来、经过哪些控制、最终造成什么影响。

计划必须绑定授权与规则

AI 红队计划必须写明授权主体、测试范围、rules of engagement、数据处理方式和停止条件。缺少这些约束的“计划”会变成不受控试探，既伤害系统安全，也削弱报告可信度。讲

者提到 Module 10 会继续使用完整 ATLAS 计划设计每一步动作；本节只做前置铺垫，不推测后续课程的具体内容。

4.3 报告项：把阶段发现转成治理语言

ATLAS 对红队的另一个贡献，是让报告不再只列技术现象。一个成熟的报告项至少要包含五个要素：阶段、风险、证据、影响、建议。阶段来自 ATLAS；风险说明被验证的问题；证据说明测试看到了什么；影响把技术现象翻译成业务后果；建议则指向缓解措施、责任团队和重新测试条件。

例如在“模型访问”阶段，报告项可以描述为：某个受控推理入口在特定测试类别下暴露出越权上下文风险，证据包括时间线、脱敏响应摘要和日志编号，影响是跨租户数据边界可能被削弱，建议是收紧上下文隔离、增强日志关联并安排回归测试。这个例子只展示报告结构，不提供攻击路径。

在“防御规避”阶段，报告项可以写成：某类异常输入未触发预期监控，证据包括测试编号、告警缺失记录和人工复核结果，影响是高风险模型行为可能进入业务流程，建议是补充检测规则、校准阈值、完善人工复核队列。这里的关键在于指出控制没有留下足够信号，避免展示具体规避方式。

读者可能没有意识到的报告难点

AI 红队报告的难点常常落在正确归因上。一个异常输出可能来自提示模板、检索库、模型本体、后处理规则、权限系统或人工流程。ATLAS 阶段能帮助定位问题发生在链条的哪一段；治理团队仍需结合日志、架构和业务语境判断根因。

4.4 本章小结

本节把讲者的短句“Red teamers 使用 ATLAS 来计划 AI 系统攻击测试”展开成授权红队的方法：先定范围，再定目标，再定义证据，最后把每个阶段发现写成报告项。ATLAS 的作用是提供阶段坐标，红队计划的作用是把坐标转成可审计、可沟通、可复测的项目材料。

与传统渗透测试攻击计划相比，AI 红队计划延续了范围、步骤、证据和报告的工程纪律，同时加入模型行为、推理接口、数据边界、内容安全控制、检索组件和人工复核流程等 AI 专属对象。读者要记住：本课程讨论的是授权测试。ATLAS 越被计划化、证据化、治理化，它对组织安全越有价值。

5 NIST AI RMF：把红队测试接入风险治理

前面几节用 MITRE ATLAS 给 AI / ML 对抗行为建立了共同语言：红队知道怎样描述阶段、技术、证据和报告项。讲者在 04:56 左右把话题转向 NIST，重点已经从“怎样规划一次 AI 红队测试”推进到“测试发现怎样进入组织的风险治理系统”。这一步很关键，因为红队测试如果只停留在演练报告里，就像体检报告只停在一张纸上；真正改变系统状态的，是后续诊断、排期、修复、复查和责任归属。

NIST AI Risk Management Framework, 简称 NIST AI RMF, 可译为“AI 风险管理框架”。它给组织提供一套管理 AI 风险的结构化语言，核心功能通常概括为四个词：Govern、Map、Measure、Manage。本文统一译为治理、映射、度量、管理。四个词看起来像并列清单，实际更接近一个闭

环：治理规定谁负责、按什么规则负责；映射说明系统处在什么业务和利益相关者语境中；度量把风险从模糊担忧变成可分析证据；管理把证据转化为优先级、响应、缓解和复测。

NIST AI RMF 把红队发现放进风险治理语言里。Govern、Map、Measure、Manage 可以理解为一个治理闭环：先定规则与责任，再识别语境风险，随后度量，最后处置和复测。

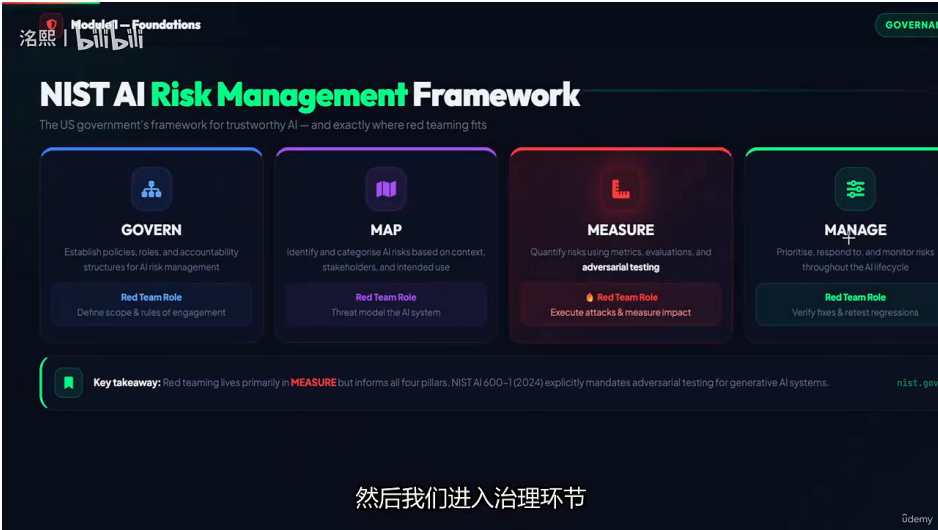


图 7: NIST AI RMF 四功能总览: Govern 负责政策、角色与问责结构, Map 识别上下文、利益相关者和预期用途中的 AI 风险, Measure 通过评估和对抗性测试度量风险, Manage 负责响应、监控和复测。⁷

在这张框架图里,红队的证据像一张检查单:Map 决定威胁建模的对象,Measure 承接测试和影响评估,Manage 接住修复、复测和生命周期追踪。



图 8: 讲者在 RMF 图上标注 Map、Measure 与 Manage 的关系: Map 侧重威胁建模与风险类别, Measure 对应测试和影响度量, Manage 指向优先级、响应与复测。⁸

⁷视频画面时间区间: 00:04:56-00:05:17; 最终抽帧时间点: 00:04:58.500。

⁸视频画面时间区间: 00:05:40-00:06:18; 最终抽帧时间点: 00:06:00.000。

NIST AI RMF 的组织价值

NIST AI RMF 的价值在于把 AI 安全问题从“技术团队发现了一个问题”提升为“组织知道这个问题属于哪类风险、由谁决策、怎样处置、何时复查”。红队测试在这个框架中提供高质量证据，治理机制负责让证据产生组织动作。

5.1 Govern 与 Map：把测试范围变成治理对象

Govern（治理）回答的是组织层面的“谁来负责、依据什么负责、如何追责”。在 AI 红队语境中，治理首先要求明确政策、角色、问责关系和授权边界。例如，红队可以测试哪些模型、哪些接口、哪些数据流，哪些行为必须提前告知，哪些高风险动作只能在隔离环境中执行，这些都属于治理安排。讲者提到红队角色需要定义 scope 和 rules of engagement，这正是 Govern 的落点。

这里的 scope 是测试范围，rules of engagement 是交战规则或演练规则。它们像实验室的安全规程：研究人员可以做实验，但实验不能越过授权边界，不能把真实用户、生产数据或未批准系统拖入风险之中。没有 Govern，红队测试容易变成一次孤立活动；有了 Govern，测试才成为组织承认、组织约束、组织吸收的风险管理动作。

Map（映射）回答的是“这个 AI 系统在什么语境里产生风险”。NIST AI RMF 中的 Map 关注上下文、利益相关者、预期用途和风险类别。对 AI 系统来说，同一个模型能力在不同语境中的风险含义会明显变化：内部辅助检索、公众问答、自动决策、代码生成、模型 API 开放给第三方，每一种场景都有不同的攻击面、影响对象和可接受风险边界。

红队在 Map 中承担的任务，是把抽象的系统描述转化为威胁建模输入。换句话说，红队需要帮助组织回答：资产在哪里，入口在哪里，攻击者可能追求什么目标，风险会影响哪些用户、业务、法律义务和声誉资产。这里可以把 Map 类比为城市地图标注：Govern 决定谁有权规划城市安全，Map 则把道路、桥梁、学校、医院和拥堵点画出来，后续度量和管理才知道该看哪里、先修哪里。

治理与映射的合成

治理与映射的关系可以写成：

$$\text{authority} + \text{context} \rightarrow \text{testable risk object}$$

其中 authority 表示授权、角色和问责，context 表示业务语境、利益相关者和预期用途。两者合在一起，才会形成可被红队测试、可被管理层讨论的风险对象。

5.2 Measure 与 Manage：从发现风险到处置闭环

Measure（度量）回答的是“风险有多真实、多严重、证据质量如何”。讲者在这一段提到分析、测试、评估影响，这对应红队测试最直接的工作区：设计对抗性测试，观察模型或系统怎样响应，记录失败模式、影响路径、触发条件和可复现证据。

度量不只意味着打分。AI 风险常常包含概率、影响、可检测性、业务语境和缓解成本等多个维度。模型行为、数据依赖、上下文误用、自动化链路放大效应，都可能让风险度量更像多指标诊断，而非单一分数。

Manage（管理）回答的是“组织准备怎样行动”。当红队发现被转写为风险项之后，管理阶段需要决定优先级、缓解措施、责任人、时间表、验收标准和复测安排。讲者提到最后阶段要处理哪些风险需要更多注意、怎样响应、怎样检查，并贯穿 AI 生命周期，这正是 Manage 的核心。

可以把红队发现进入治理处置的过程写成一个简洁闭环：

finding → risk → decision → mitigation → retest

其中 finding 是红队观察到的具体发现，risk 是结合业务语境后的风险表述，decision 是治理主体作出的处置决策，mitigation 是缓解或修复动作，retest 是复测。这个链条说明，红队报告不是终点，它是风险管理循环中的证据入口。

报告不能停在精彩发现

红队测试报告如果缺少风险归属和处置路径，很容易变成“精彩但不可执行”的材料。真正有用的报告需要让读者知道：这个发现属于哪类风险，影响谁，由谁决定，如何缓解，什么时候验证缓解是否有效。

5.3 红队在四大功能中的位置

讲者给出的关键判断是：Red teaming 的主要活动靠近 Measure / testing，但它会影响全部四个功能。这个判断很重要，因为它避免把红队缩小成单纯的测试按钮。红队确实通过对抗性测试产生证据，所以它最密集地出现在 Measure；但红队要合法、有效、可复查地运行，必须由 Govern 授权，由 Map 提供风险语境，并由 Manage 吸收结果。

因此，红队在 NIST AI RMF 中可以理解为一个穿过四个功能的证据管线。Govern 给它边界，Map 给它目标，Measure 给它方法和证据，Manage 给它行动闭环。四者的关系像一套生产线：治理负责制度和权限，映射负责原料识别，度量负责检测与质检，管理负责放行、返工或升级处置。任何一环断掉，红队测试都会失去一部分治理价值。

四功能闭环

四个功能的简化关系如下：

Govern → Map → Measure → Manage ↻

箭头表示风险治理的推进方向，循环箭头表示管理结果会反过来更新政策、范围、测试标准和下一轮风险映射。

5.4 本章小结

本节首次定义了 NIST AI RMF，并把 Govern、Map、Measure、Manage 解释为一套风险治理闭环。Govern 建立政策、角色和问责边界；Map 把 AI 系统放入上下文、利益相关者和预期用途之中；Measure 通过测试和分析把风险变成证据；Manage 负责优先级、响应、缓解和复测。红队测试的直接工作集中在 Measure 附近，但它的授权、目标、证据和处置分别连接四个功能。对组织而言，红队发现只有进入 *finding → risk → decision → mitigation → retest* 这条链路，才真正完成从技术发现到治理动作的转化。

6 NIST AI 600-1、对抗性测试与后续 C2C 伏笔

在视频最后一分钟，讲者把前面的 ATLAS 和 NIST AI RMF 收束到一个更具体的要求上：NIST AI 600-1 (2024) 明确提出 *adversarial testing* 的重要性。这里的 *adversarial testing* 可译为对抗性测试，指在授权和受控条件下模拟对手行为、误用路径或压力场景，用来创建、评估或改进

AI 系统。它和前文红队测试高度相关：红队提供对手视角，对抗性测试提供验证方式，风险管理框架提供组织吸收这些结果的容器。

需要注意，视频在这里没有展开 NIST AI 600-1 的完整条款，也没有把它解读成法律结论。讲者使用它的方式很清晰：它是一个信号，说明对抗性测试已经被放进 AI 风险管理和生成式 AI 配置文件的正式语境中。换句话说，红队测试不再只是安全团队的“额外演练”，它正在成为 AI 生命周期中需要反复执行、记录和复查的工程活动。

最后一节把前面的 ATLAS 与 NIST 收束到同一条链路：ATLAS 给红队提供测试剧本，NIST AI RMF 给组织提供风险治理容器。

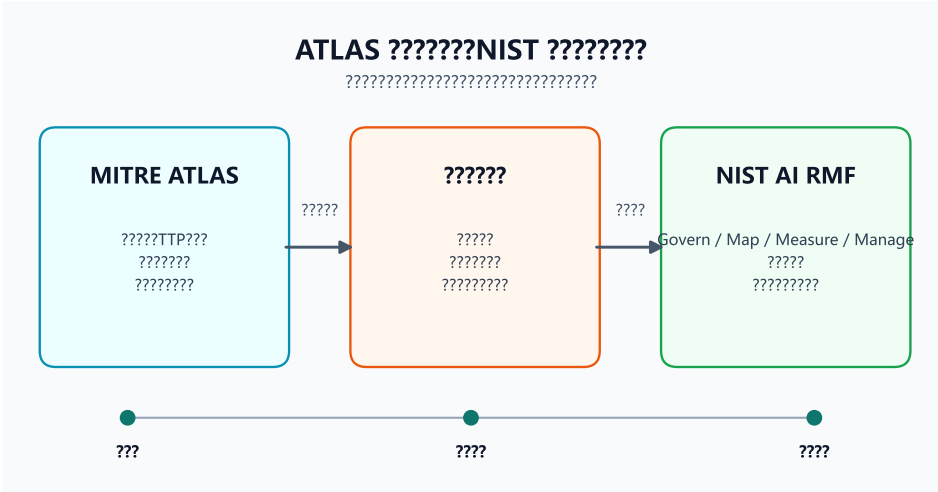


图 9: 教学示意图: ATLAS 将阶段链条、TTP 与证据组织成测试剧本; 红队测试结果再进入 NIST AI RMF 的治理闭环, 成为可处置、可复测、可追责的风险项。⁹



图 10: NIST AI 600-1 与 adversarial testing: 画面底部关键句指出 red teaming 主要活跃在 Measure 附近, 同时会影响四个功能, 并提到 NIST AI 600-1 对生成式 AI 系统的对抗性测试要求。¹⁰

课程结尾切到 C2C Methodology, 它在本视频中只作为下节课接口出现, 当前 fragment 仅保留过渡证据, 避免扩写其方法细节。

⁹ 视频画面时间区间: 00:06:18–00:06:54; 该图为基于本节收束关系生成的教学示意图。
¹⁰ 视频画面时间区间: 00:06:54–00:07:06; 最终抽帧时间点: 00:07:00.000。



图 11: C2C Methodology 过渡页：画面出现 C2C Methodology 与下节课入口，本节仅记录屏幕文字和课程衔接，不展开方法含义。¹¹

NIST AI 600-1 的定位

NIST AI 600-1 (2024) 在本课中的作用，是把 adversarial testing 从经验性安全实践推向框架化要求。红队测试由此获得了一个更清楚的位置：它服务于 AI 系统的创建、评估、上线前验证、上线后复查和持续改进。

6.1 红队测试在 AI 生命周期中的回路

AI 生命周期可以粗略理解为需求定义、数据准备、模型开发、系统集成、部署运行、监控更新和退役迁移等阶段。传统软件安全常把测试安排在上线前后几个关口；AI 系统的风险更动态，因为模型行为会随数据、提示词、工具调用、外部插件、业务场景和用户群体变化而变化。因此，红队测试需要形成回路，而不能只做一次性验收。

这个回路至少包含三层含义。第一，测试要前移：在系统设计和威胁建模阶段，红队已经可以帮助识别资产、入口、滥用场景和潜在影响。第二，测试要嵌入：在开发、评估和部署阶段，对抗性样例、误用场景、越权路径、模型拒答边界和监控信号都需要被纳入验证。第三，测试要回流：上线后的事件、用户反馈、新攻击知识和模型更新，会推动下一轮测试计划重新生成。

可以把这个生命周期回路写成：

design → test → deploy → monitor → retest

其中 design 表示设计和威胁建模，test 表示对抗性测试与红队评估，deploy 表示部署，monitor 表示运行监控，retest 表示基于新证据的复测。这个表达强调，红队测试不只关心“某一次有没有攻破”，还关心系统怎样在反复验证中变得更可控。

生命周期回路

生命周期回路的直觉类似桥梁养护：建桥前要看地质和车流，通车前要做承载测试，通车后还要监测裂缝、风载和疲劳。AI 系统也是这样，模型上线不代表风险结束，上线只是进入了新的观察和复测阶段。

¹¹ 视频画面时间区间：00:07:06–00:07:15；最终抽帧时间点：00:07:07.000。

6.2 NIST AI 600-1 对 adversarial testing 的要求

根据本视频的讲解，NIST AI 600-1 (2024) 明确要求使用 adversarial testing 来创建或评估 AI 系统。这里的“创建或评估”非常值得咀嚼：对抗性测试既可以在系统形成过程中暴露设计弱点，也可以在系统完成后评估残余风险。前者偏向建设期的安全设计，后者偏向验证期的风险确认。

对抗性测试在这里承担的是“压力试验”角色。普通功能测试会问系统能否完成预期任务，对抗性测试会追问系统在诱导、误用、边界输入、上下文污染或攻击者目标驱动下会怎样表现。二者组合起来，才能更接近真实世界。因为真实世界中的 AI 系统经常面对不友善输入、模糊需求、链式工具调用和跨系统数据流，单纯验证“正常路径可用”远远不够。

从风险治理角度看，NIST AI 600-1 的要求可以接入上一节的闭环：测试产生 finding，组织把 finding 映射成 risk，再由治理机制做 decision，随后进入 mitigation 和 retest。这里的关键不在于堆更多测试案例，而在于让测试结果能够被记录、复现、解释和追踪。

对抗性测试的边界

对抗性测试不等于无限制攻击演练。它需要授权、范围、保护措施和结果处置机制。缺少这些条件，测试本身也可能制造新的系统风险、数据风险和合规风险。

6.3 C2C 与下一个视频接口

讲者最后提到，接下来会讨论 C2C 方法。按照本视频素材，C2C 只能作为后续视频要讨论的方法保留伏笔；当前章节不扩写其含义，也不提前推断它的完整方法论。这样处理更诚实，因为视频只给出了名称和下集提示，没有提供足够证据支持进一步展开。

不过，从结构上看，C2C 的出现位置很有意义。前面 ATLAS 解决的是“怎样描述 AI 对抗行为、怎样规划红队测试”；NIST AI RMF 解决的是“怎样把测试发现纳入治理闭环”；NIST AI 600-1 (2024) 则强调 adversarial testing 的必要性。C2C 被放在这些内容之后，说明讲者准备把框架级语言继续推进到某种后续方法。至于该方法具体怎样定义，需要等待下一条视频的材料确认。

C2C 的保守处理

本课到 C2C 之前已经建立了三层台阶：ATLAS 提供测试语言，NIST AI RMF 提供治理闭环，NIST AI 600-1 (2024) 提供对抗性测试要求。C2C 是下一节课的入口，不应在当前材料中提前定型。

6.4 本章小结

本节说明了 NIST AI 600-1 (2024) 在课程收束中的位置：它明确强调 adversarial testing，用来创建或评估 AI 系统。红队测试由此被放入 AI 生命周期回路之中，从设计、测试、部署、监控到复测持续发挥作用。CVSS 这类传统漏洞评分体系可以作为背景参照，提醒读者安全风险需要度量语言；但本视频没有展开 CVSS 公式、向量或评分细节。最后，C2C 仅作为后续视频要讨论的方法出现，本节保留伏笔，不扩写含义。

7 总结与延伸

这节课的收束很紧：讲者先用 MITRE ATLAS 建立 AI 红队的共同语言，再用 NIST AI RMF 把红队发现放进治理闭环，最后用 NIST AI 600-1 (2024) 强调 adversarial testing 已经成为 AI 风

险管理中需要认真对待的要求。整条线可以概括为：

ATLAS language → red-team evidence → RMF governance → lifecycle retesting

ATLAS language 表示攻击阶段、技术和证据的描述语言；red-team evidence 表示红队测试得到的发现；RMF governance 表示组织治理、映射、度量和管理的；lifecycle retesting 表示贯穿 AI 生命周期的复测。

Codex 的综合提炼是：AI 红队的成熟度不只看能否发现问题，还要看发现能否被组织吸收。能发现问题，说明测试能力存在；能把问题映射为风险，说明风险语言存在；能让风险进入决策、缓解和复测，说明治理能力存在。三者叠在一起，AI 红队才从一次演示走向长期工程。

框架化路线

本视频的核心落在套框架化路线上：用 ATLAS 描述对抗行为，用 NIST AI RMF 接住测试发现，用 NIST AI 600-1 (2024) 强化对抗性测试要求，再把后续 C2C 作为下一节方法讨论的入口。

7.1 给读者的三个带走判断

第一，AI 红队需要一套共同语言。没有共同语言，团队会把同一件事说成很多碎片：有人说“模型被诱导”，有人说“接口暴露”，有人说“数据外流风险”，有人说“治理缺口”。ATLAS 的意义在于把这些碎片放进同一张坐标图，让攻击意图、实现方式、证据和报告项能够互相对齐。它像一张城市交通图，路名、站点、换乘关系和事故记录放在一起，沟通成本会明显下降。

第二，AI 红队需要被治理机制接住。一次漂亮的测试发现，如果没有进入风险登记、责任分配、优先级排序和复测安排，很快会变成一段只能回忆的演示。NIST AI RMF 的价值就在这里：Govern 给测试合法边界，Map 给测试业务语境，Measure 让测试变成证据，Manage 让证据进入处置。读者可以把它想成医院流程：检查能发现病灶，但治疗计划、复查周期和责任医生同样决定结果。

第三，对抗性测试需要贯穿 AI 生命周期。AI 系统的行为会随模型版本、提示词、检索库、工具权限、用户群体和业务场景变化而漂移。一次上线前测试不能覆盖长期运行风险。更稳妥的方式，是把红队测试做成循环：设计阶段参与威胁建模，开发阶段设计对抗用例，上线前验证边界，上线后根据监控和事件复测。这样，安全工作才有记忆，也有反馈。

7.2 后续学习的检查表

读完本节后，读者可以用一个小检查表判断自己的组织是否真正准备好做 AI 红队。第一，是否有明确授权和交战规则；第二，是否知道 AI 系统的资产、入口、模型访问方式、数据流和工具调用边界；第三，是否能把每个发现记录为可复现证据；第四，是否有机制把发现转成风险项；第五，是否安排了缓解后的复测。少掉其中任何一项，红队测试都会在某个环节失去治理价值。

下一节 C2C 方法值得期待的地方，也在这张检查表里。当前视频只把它作为课程入口，尚未定义细节；但从上下文看，讲者很可能要把框架语言继续推进到更具体的工作方法。学习者在进入下一节之前，可以先带着两个问题：C2C 会怎样把概念、链路和妥协场景组织成测试路径；它又会怎样避免从风险验证滑向无授权操作。带着问题进入后续内容，往往比只等答案更有效。